

CS 03506

CYBERSECURITY MANAGEMENT, POLICY, AND RISK

CYBERSECURITY PROGRAM FOR GREEN FOODS MARKET

Group Members:	Dinos Klentzeris Gabriel Montes Devon Jacob
Instructor:	Sally Tarabah
Date:	12/18/2024

Table of Contents

1.0 Introduction	3
2.0 Program Foundation	4
2.1 Goals and Objectives	4
2.2 Summary of Previous Findings	4
2.3 Budgetary Considerations	5
3.0 Program Framework and Compliance	6
3.1 Framework Overview	6
3.2 Compliance and Standards	6
4.0 Risk Management and Physical Security	7
4.1 Risk Management Strategies	7
4.2 Physical Security Measures	7
5.0 Cybersecurity Leadership & Workforce Development	8
5.1 Leadership Overview	8
5.2 Personnel Roles and Security	8
5.3 Training Plan	9
6.0 Policy, Technology, and Asset Management	10
6.1 Policy Development	10
6.2 Technology and Tools	10
6.3 Data Classification	11
6.4 Asset Management	11
7.0 System Security and Maintenance	13
7.1 Configuration Management	13
7.2 Patch Management	13
7.3 Network Security	14
7.4 Website Security	14
7.4.1 Social Media	14
8.0 Program Monitoring and Future Outlook	15
8.1 Ongoing Monitoring and Evaluation	15
8.1.1 Key Performance Indicators (KPIs)	15
8.1.2 Review Schedule of the Cybersecurity Program	15
8.1.3 Continuous Improvement Methodology	16
8.1.4 Reporting	16

8.2 Conclusion	16
9.0 Revision History Table.....	17
9.1 Change Control Process.....	17
Appendices	18
Appendix A – Sample Policy	18
Appendix B – Sample Standard.....	20
Appendix C – Sample SOP	22

Figures and Tables

Figure 1- Modifying an Item in the Store Database via Menu System	25
Table 1-Green Foods Market Key Operations	3
Table 2-Green Foods Employees and Relevant Checks	8
Table 3-Cybersecurity Technology and Tools	10
Table 4 - Hardware Assets Tracking	12
Table 5 - Software Licenses Tracking	12
Table 6-Patch Priority	13
Table 7 - Revision History Table	17
Table 8-Contact	18
Table 9-SOP Revision Table.....	24

1.0 Introduction

Green Foods Market employs 6-year-round staff, with seasonal employees hired during peak times. The company operates a fresh produce store located in Glassboro, New Jersey, and conducts business locally through both in-store and online operations. Green Foods Market's annual profits are \$150,000, with \$7,500 allocated annually to cybersecurity.

Green Foods Market Key Operations	
In-Store Functions	Employees serve customers, stock shelves, ensure store cleanliness, and build appearance.
Online Functions	Third-party website contractors ensure the online store is available, allowing customers to order fresh produce from the main location to any address within a 50-mile radius.
Inventory Management	Employees track online and in-store inventory and purchase more, when necessary, from local farms and bakeries.
Customer Service	Employees handle phone, online, and in-store inquiries while placing delivery orders and ensuring each customer has a pleasant shopping experience.
Product Acquisition	Management makes connections with local produce providers and cultivates bakery partnerships while also regularly ordering products for inventory and managing deliveries.
Finances	POS system ensures customer payment data both online and in-store is processed securely and efficiently.
IT and Cybersecurity	Contractors ensure in-store systems are functioning and up to date while maintaining payments systems and the website to prevent PII breaches or service interruptions.
Delivery	Employees manage online and phone deliveries to customers' homes within 50 miles to ensure quick and fresh arrivals.
Payroll	Management ensures employees get paid the proper amount at the proper time.

Table 1-Green Foods Market Key Operations

2.0 Program Foundation

2.1 Goals and Objectives

The Green Foods Market cybersecurity program has the main objective of protecting the integrity and privacy of company, employee, and customer personal identifiable information (PII) as well as ensuring business resilience. To accomplish this goal, the following objectives must be met:

1. Secure Client and Business Data
2. Maintaining System Integrity and Availability
3. Protect Financial Transactions
4. Developing an Incident Response and Recovery Plan
5. Promote Cybersecurity Awareness Among Staff and Partners
6. Ensure the smooth operations of in-store and online POS systems
7. Protect customer payment information online and in-store
8. Ensure availability of the online store catalogue and in-store network
9. Keep in-store hardware operational and available.

As such, this cybersecurity program will strive to meet the following goals:

1. Secure all in-store and online software and hardware assets with anti-malware and intrusion detection systems (IDS) in the span of 6 months with the goal of eliminating 95% of cybersecurity breaches.
2. Develop an updated, mandatory annual cybersecurity awareness program covering all necessary knowledge presented in this document within 2 months. This program will be mandatory training for all full-time and part-time employees, as well as for contractors.
3. Upgrade all POS hardware and website software to modern systems to ensure the highest possible efficiency and eliminate 100% of legacy vulnerabilities.

2.2 Summary of Previous Findings

A security audit conducted on 9/27/2024 revealed some major cybersecurity vulnerabilities in Green Foods Market's operations. Namely, because IT is contracted out to a third-party company, there are no in-house cybersecurity policies, with the exceptions of password standards. The store database is hosted in the cloud with no local copies being maintained, meaning the disruption of third-party services would render the business without information. There is no robust emergency response plan, communication plan, or disaster plan testing available, and it has been determined that the success of a social engineering attack or exploitation of unenforced security policies is high.

Because Green Foods Market is a produce-focused retailer, the most vital service to maintain in case of disruption is refrigeration, as food will begin to go bad after 8 hours of room temperature storage conditions. All other aspects of the business have maximum tolerable downtimes (MTDs) of no less than 24 hours. To ensure operations meet the recovery time objective in the event of a

business disruption, a business continuity plan was formulated on 11/04/2024 to outline steps management should follow to return facilities to normal operations. This includes strategies for utility disruptions, which includes notifying the utility company and contracted IT support team; infrastructure or cloud service outage, which includes deploying IT on-site or remotely; location unavailability, which includes setting up a temporary sales unit and coordinating plans among employees; supply chain disruption, which includes contacting local farms and bakeries to procure emergency backup stock; data loss or cybersecurity incident, which includes investigating loss and contacting IT to isolate systems and repair damage; and emergency response training, which includes knowledge sessions, drills, and role-specific education.

2.3 Budgetary Considerations

As a small business, Green Foods Market's budget for an annual cybersecurity program is merely \$7,500, which is 5% of its \$150,000 annual earnings. Specific expenses include the following list:

- \$179.99 –ESET Small Business Security 1-Year Subscription was purchased¹.
- \$755.90 - Cisco Firepower 1010 NGFW Appliance² was acquired.
- \$799.96 – 4 Ring Floodlight Camera Pro³ were purchased and installed for outside security.
- \$824.94 – 3 Dell OptiPlex 3070 Desktop computers were 3 bought for office use⁴.
- \$359.96 – 4 Ring Stick Up Camera Pro⁵ were purchased and installed for indoor monitoring.
- \$164.25 – 3 Uninterrupted Power Supply APC 650VA 120V Backups⁶ were purchased.
- \$648.00 – Annual subscription to Cynet Intrusion Detection System⁷.
- \$79.80 – Purchased and installed 4 Emergency Backup Light⁸.
- \$103.90 - Ceiling Mounted 360 Degree Motion Detector⁹.
- \$1072.00 – Cyber Insurance¹⁰.
- \$187.20 – Annual subscription of \$62.40 each for Symantec Endpoint Encryption¹¹
- \$245.00 – Annual Subscription ManageEngine Patch Manager¹²
- \$59.96 - Barracuda Total Email Protection at \$14.99 per user¹³
- \$1590.00 – 2 Grocery Store Point of Sale (POS) Cash Register Kit¹⁴ were purchased.

Total \$7070.86

¹ <https://www.eset.com/us/home/small-business-security/>

² <https://www.secureitstore.com/Firepower-1010>

³ <https://ring.com/products/floodlight-cam-pro/color/white/power/wired/multipack/4-pack>

⁴ <https://discountcomputerdepot.com/dell-optiplex-3070-intel-core-i5-8gb-ram-256gb-ssd-19in-lcd>

⁵ <https://ring.com/products/stick-up-cam-pro-plug-in>

⁶ <https://www.connection.com/product/apc-650va-120v-back-ups-w-8-nema-outlets-4-surge>

⁷ https://www.cynet.com/packages/?utm_medium=display_ad&utm_source=cyber_security_news&utm

⁸ <https://www.emergencylight.net/emergency-backup-light>

⁹ <https://www.alarmsystemstore.com/products/dsc-bv500-bravo-5-ceiling-mdsc-bv500-bravo-5>

¹⁰ <https://advisorsmith.com/business-insurance/cyber-liability-insurance/cost-by-industry/>

¹¹ <https://www.genesis-technologies.com/products/symantec-endpoint-encryption>

¹² <https://www.manageengine.com/patch-management/pricing.html>

¹³ <https://www.cdw.com/product/barracuda-total-email-protection-subscription-license-1-user/5753890>

¹⁴ <https://pointofsalepos.com/products/grocery-store-point-of-sale-pos-cash-register-bundle-22-lcd>

3.0 Program Framework and Compliance

3.1 Framework Overview

This cybersecurity program will be implemented and overseen by the store owner and the contracted IT team. The owner and IT will work together to fill the following responsibilities:

- Meeting at least once every three months to establish whether the guidelines are successfully implemented or not and make updates to the program.
- The implementation and delivery of cybersecurity awareness training for all employees.
- Assisting other employees in following cybersecurity guidelines and enforcing policies.
- Acting as the first responder to any cybersecurity breaches along with the store owner.
- Ensuring the company maintains compliance with any relevant New Jersey cybersecurity regulations.

3.2 Compliance and Standards

Due to it being a retail store in New Jersey, Green Foods Market will need to ensure compliance with the New Jersey Privacy Act and the Payment Card Industry Data Security Standard.

New Jersey Privacy Act (NJPA) requires the following:¹⁵

- Provide customers with notice if their personal data is processed, access to said personal data, ability to correct personal data, and an opt-out option.
- Respond to customer requests regarding personal data within 45 days, provide free copies of personal information to customers every 12 months, and make reasonable efforts to authenticate requests.
- Draft an accessible, clear, and appropriate privacy notice providing customers knowledge of how the business processes personal information, what personal data is processed, how customers can exercise their rights, and a method for business contact.
- Enact data protection impact assessments for data processing, limit the collection of personal data to what is necessary, and maintain security policies and practices for protection of personal data.

The Payment Card Industry Data Security Standard (PCI DSS) requires the following:¹⁶

- Implementation of a firewall and antivirus software to secure customer credit card data.
- Secure password policies for POS items.
- Encryption of customer credit card data in storage and transit.
- Properly updated software to ensure legacy vulnerabilities are eliminated.
- Credit card holder information should be available only to individuals who absolutely need to know, and physical access to hardware containing said information should be restricted.
- All security systems must be tried and tested regularly to ensure proper functionality.
- Access logs must be kept for systems that process credit card holder data, and security policies must be documented.

¹⁵ <https://natlawreview.com/article/new-jersey-adopts-comprehensive-data-privacy-law>

¹⁶ <https://www.forbes.com/advisor/business/what-is-pci-compliance/>

4.0 Risk Management and Physical Security

4.1 Risk Management Strategies

Effective risk management is vital for Green Foods Market to protect its operations, assets, and profits. To ensure the business remains resilient against various threats, the following strategies will be implemented:

- Performing routine assessment to identify vulnerability in online and in-store operations, including payment systems, inventory management, and delivery logistics. Also, evaluate the likelihood and potential impact of each identified risk.
- Installing cybersecurity measures such as firewalls, antivirus software, and intrusion detection systems.
- Developing clear procedures for data handling, payment processing and IT system access to reduce risk exposure.
- Purchase cybersecurity insurance to transfer financial risk associated with data breach or other cyber incidents.
- Develop an Incident Response Plan and test the plan annually to ensure readiness for various emergency scenarios.
- Reviewing compliance measures bi-annually to ensure adherence to current legal requirements.

4.2 Physical Security Measures

To protect the company's physical assets, ensure customer and employee safety, and enhance cybersecurity, Green Foods Market will implement the following physical security measures using its allocated budget in section 2.3.

- Physical barriers:
 - Perimeter fencing
- Surveillance and Monitoring:
 - 8 security cameras – 4 cameras indoor and 4 outdoor cameras with lights
- Environmental Controls:
 - Fire suppression systems such as fire extinguishers and fire alarms
 - Temperature sensor
- Security Lighting
 - Exterior motion activated lighting near the main entrance and back doors.
 - Emergency and backup lighting
- Intrusion Detection System
 - Motion sensors
 - Glass break detector
- Perimeter Security
 - Reinforced door locks with deadbolt locks
- Security and Warning Signs
 - Visible "Video Surveillance" signs at entrances

5.0 Cybersecurity Leadership & Workforce Development

5.1 Leadership Overview

For Green Foods Market, the store owner oversees enforcing and maintaining cybersecurity standards, although each employee is responsible for compliance with company cybersecurity policies. The contracted IT team is responsible for implementing Green Foods Market cybersecurity practices on all cloud services and local machines, as well as the store website.

5.2 Personnel Roles and Security

The following table provides an overview of Green Foods Market's employees' roles, background checks, employment group, and privileges.

Employee Position	Background Checks	Employment Group	Computer Privileges
Store Owner/ Manager	Check for criminal history, substance abuse history, credit history, previous employment history, social media history, education history, references legitimacy, and drug test	Management	Administration account with access to all systems
Delivery Driver	Check for criminal history, previous employment history, social media history, driving history, and drug test	Delivery	Employee account with access to the digital time clock
Store Clerk	Check for criminal history, previous employment history, social media history, education history, and drug test	Clerk	Employee account with access to POS systems and the digital time clock
Temporary Staff		Temporary	
IT Support (contractor)	Check for employment legitimacy, success history, references' legitimacy, and drug test	IT	Administration account with access to all in-store systems
Website Support (contractor)		IT	Administration account with access to all online systems

Table 2-Green Foods Employees and Relevant Checks

As an aside, all employees with administration accounts will be provided with regular user accounts with limited access to all systems, including POS, time clock, and database viewer.

5.3 Training Plan

As the most important aspect of any cybersecurity plan, employee training is paramount to ensuring good practices are followed and policies complied with. Due to the small number of employees, the owner and at least one IT member will conduct in-person meetings with all staff to provide training in the standards laid out in this document. Cybersecurity training meetings will take place on time of hire and once every six months. Because the owner and IT team oversee cybersecurity, a special meeting will be held every six months among both sections to share information and cybersecurity knowledge. The topics covered in the training plan are listed below:

The topics covered in the training plan are listed below:

1. Management training Plan
 - a. Training Topics:
 - i. Overview of the most critical potential threats to business cybersecurity.
 - ii. Review of any cybersecurity incidents since the previous meeting.
 - iii. Developing and implementing an effective incident response plan.
 - iv. Ensuring organizational compliance with the New Jersey Privacy Act (NJPA).
 - v. Best practices for promoting cybersecurity awareness in the company.
 - vi. Allocating funds for cybersecurity initiatives.
2. IT Training Plan
 - a. Training Topics
 - i. Understanding essential network security such as firewalls, intrusion detection and network segmentation.
 - ii. Discussion on the current cybersecurity policies and how to always ensure the company's compliance with local regulations.
 - iii. Hands-on training in securing the business's main devices such as desktop computers, point-of-sale (POS) systems and mobile delivery phones.
 - iv. Workshops on threat detection, reporting and mitigating cyber incidents such as data breaches.
 - v. How to execute an incident response plan during a cybersecurity emergency.
3. Clerk Training Plan:
 - a. Training Topics:
 - i. Teaching clerks on identifying phishing attacks, recognizing social engineering tactics and best practices for creating and maintaining secure password.
 - ii. Educating clerks on data privacy and how to always safeguard customer's payment information during transaction.
 - iii. Discussion on role specific responsibilities in the event of a cybersecurity incident.
4. Delivery training topics:
 - i. Best practices for securing mobile devices used for delivery.
 - ii. Ensure that company devices are locked and protected during delivery.
 - iii. Reporting any suspicious activity during delivery.

6.0 Policy, Technology, and Asset Management

6.1 Policy Development

To strengthen the Green Foods Market's cybersecurity framework, it is essential to develop and implement the following relevant policies. Detailed examples and guidelines can be found in Appendix A.

- Information Security Policy
- Access Control Policy
- Acceptable Use Policy
- Data Breach Response Policy
- Data Classification Policy
- Email Policy
- Encryption Policy
- Incident Response Policy
- Internet Usage Policy
- Mobile Device Management Policy
- Network Security Policy
- Password Policy
- Physical Security Policy
- Remote Access Policy
- Removable Media Policy
- Social Media Policy

6.2 Technology and Tools

All cybersecurity tools relevant to Green Foods Market are listed below. New tools must be purchased and repurposed tools must be reconfigured to align with this plan.

Cybersecurity Tools	
Firewall	Cisco Firepower 1010 NGFW Appliance
Antivirus and Antimalware	ESET Small Business Security
Intrusion Detection System (IDS)	Cynet Intrusion Detection System
Encryption Tools	Symantec Endpoint Encryption
Endpoint Detection and Response (EDR)	
Phishing Protection Solutions	Barracuda Total Email Protection
Patch Management Software	ManageEngine Patch Manager

Table 3-Cybersecurity Technology and Tools

6.3 Data Classification

Green Foods Market does not process or store vast amounts of personal data. The few types of sensitive information stored by the business are listed below.

The following types of information are considered confidential and are not to be exposed to the public. This data should be encrypted, as the loss of said data would pose a significant business and security risk.

- Business secrets and expansion plans
- Vendor and contractor information
- Legal documents
- Security policy documents
- Customer payment information.

The following types of information are considered restricted to only in-store employees and the owner, as exposure to this data would be considered a security breach.

- Financial and project documents
- The PII of employees hired
- Noncompromising customer information, such as names, addresses, and account usernames
- Software and hardware configurations
- Company reports and reviews.

The following types of information are considered internal use only and would not cause a significant issue if exposed to the public but should not be exposed purposely.

- Product lists and prices
- Policy documents not relating to security
- Documents for business events and practices
- Training programs and employee schedules

6.4 Asset Management

Green Foods Market has the following assets:

Type	Hardware Category	Serial Number
Desktop	Computing Equipment	GF-DES-001
Desktop	Computing Equipment	GF-DES-002
Desktop	Computing Equipment	GF-DES-003
Laptop	Computing Equipment	GF-LAP-001
Router	Network Hardware	GF-ROU-001
Cisco Firepower 1010	Network Security Appliance	GF-FWP-001

Point-of-Sale (POS) Terminal	Payment Processing Equipment	GF-POS-001
Point-of-Sale (POS) Terminal	Payment Processing Equipment	GF-POS-002
Mobile Device	Portable Devices	GF-MOB-001
Mobile Device	Portable Devices	GF-MOB-002
Uninterruptible Power Supply	Power Backup Equipment	GF-UPS-001
Uninterruptible Power Supply	Power Backup Equipment	GF-UPS-002
Uninterruptible Power Supply	Power Backup Equipment	GF-UPS-003
Printer	Printing Equipment	GF-PRT-001
Surveillance Cameras (8)	Security Equipment	GF-CAM-001 to GF-CAM-008
Antivirus Software	Security Software	GF-ANT-001
Motion Sensor	Security/Monitoring Equipment	GF-MSN-001

Table 4 - Hardware Assets Tracking

Green Foods Market utilizes the following software licenses:

Type	Software Category
QuickBooks	Accounting and Billing Software
FoodDocs	Compliance and Regulatory Software
HubSpot	Customer Relationship Management Software
Track-POD	Delivery and Logistics Software
Square for Retail	Inventory Management
Square Payroll	Payroll Software
Square POS	Point of Sale Software
Microsoft 365 (3)	Productivity Software
ESET Small Business Security	Security Software
Barracuda Total Email Protection	Email Security Software
ManageEngine Patch Manager	Patch Management Software
Symantec Endpoint Encryption	Encryption Software
Cynet Intrusion Detection System	Intrusion Detection Software

Table 5 - Software Licenses Tracking

7.0 System Security and Maintenance

7.1 Configuration Management

IT systems in Green Foods Market must be configured properly to avoid presenting security loopholes to potential intruders. The hardware that requires configuration includes office computers, POS systems, and security cameras. The software that requires configuration includes employee time clock, payroll system, database, website, and camera monitoring program. The configuration procedures are as follows:

- 1) Determine system use and requirements
- 2) Perform and tweak initial configuration
- 3) Create configuration policy
- 4) Modify configuration regularly based on employee feedback
- 5) Review configuration every six months and update policy based on changes made and emerging threats
- 6) Implement antivirus and intrusion detection system to catch unauthorized modifications to the configuration.

7.2 Patch Management

It is imperative that software is kept up to date with the latest patches and updates to prevent known exploits from being taken advantage of by bad actors. The procedures for managing patches are as follows:

1. Develop a policy that specifies when a patch should be installed and by whom. Whether or not patches are automatically installed should be decided on a case-by-case basis depending on the damage a bad patch could do.
2. Stagger patch releases to ensure corrupted patches do not disable all systems at once. For example, update each piece of POS hardware one day at a time.
3. Install patches in order of importance based on the vulnerabilities addressed and the necessity of the system. The following table outlines the patch priority hierarchy:

Patch Priority	Risk Level	Time to install
Emergency	Catastrophic Risk if not patched	24 – 48 hours
High	Imminent risk if not patched	1 – 2 weeks
Medium	Some risk if not patched	1 month
Low	Little to no risk if not patched	3 – 4 months
Emergency	Catastrophic Risk if not patched	24 – 48 hours

Table 6-Patch Priority

4. Review the patch policy every six months to ensure it is still effective and being used.
5. Create an emergency response plan for installing patches that fix catastrophic exploits.

7.3 Network Security

To ensure Green Foods Market's store network is fast, secure, and available, the following measures must be taken:

1. Segment the network to facilitate quick isolation of infected machines should malware be introduced.
2. Change the default passwords of all network devices in compliance with the password policy.
3. Install an antivirus/IDS on each device.
4. Configure the software firewall to only accept appropriate traffic and deploy a hardware firewall to create a demilitarized zone.
5. Set up public and private Wi-Fi networks for customers and employees to access respectively.
 - a. Employee Wi-Fi should be password-protected and encrypted.
6. Install Multi-Factor Authentication for every account or device that requires a password.
7. IT team survey the network every six months to detect vulnerabilities or install new features.
8. Hire a contractor to conduct penetration testing once per year.
9. Ensure all screens are locked when a computer is not in use.
10. Train all employees on the importance of network safety and security.

7.4 Website Security

Because Green Foods Market's website processes customer data and facilitates user accounts, it is imperative that the system is secure as per the following requirements:

1. Ensure the website always runs on HTTP secure.
2. Install updates and patches to the web server as per the patch management policy.
3. Enforce the password policy for all user credentials on the front and back end.
4. Deploy MFA on the front and back end.
5. Back up the website daily.
6. Enforce the customer PII management policy for all customer data stored on the server.
7. Schedule bi-monthly vulnerability scans of the web server to detect any unusual activity.
8. Encrypt all payment data being processed or stored on the website.
9. Block any non-USA IP addresses.

7.4.1 Social Media

Although Green Foods Market is a small business, it does have a social media presence managed by the store owner. The following rules should be followed to ensure the availability and security of all social media accounts:

1. Ensure the password policy is followed for all social media accounts.
2. Use MFA for all accounts.
3. Do not remain signed in to social media accounts on public devices.
4. Remain professional in all posts and refrain from engaging with suspicious individuals.

8.0 Program Monitoring and Future Outlook

8.1 Ongoing Monitoring and Evaluation

To ensure Green Food Market's cybersecurity program remains effective, continuous monitoring and evaluation will be implemented.

8.1.1 Key Performance Indicators (KPIs)

- 1) Data Encryption Implementation:
 - a. KPI: Percent of customer payment and personal information encrypted end-to-end within one year.
 - b. Target: 100% of all sensitive customer data encrypted.
- 2) Cybersecurity Audit Efficiency
 - a. KPI: Percentage decrease in vulnerabilities detected during annual security audits.
 - b. Target: Achieve 15% reduction between audits.
- 3) Training Completion
 - a. KPI: Employee participation in cybersecurity training.
 - b. Target: 100% of employees complete training within six months.
 - c. KPI: Employees scoring 90% or higher on training assessments.
 - d. Target: Retakes permitted for all employees.
- 4) Security Incident Response Time
 - a. KPI: Average time from identifying to resolving security incidents.
 - b. Target: Reduce resolution time by 25% compared to the previous year.
- 5) Patch Implementation Timeline
 - a. KPI: Time between applying critical system patches post-release.
 - b. Target: 100% of critical patches installed within 20 days of release.
- 6) Data Breach Incidents
 - a. KPI: Number of data breaches involving customer payment information or PII.
 - b. Target: Ensure 0% data breach resulting from system vulnerabilities or errors in data handling practices.
- 7) Endpoint Security
 - a. KPI: Percentage of devices with updated antivirus and firewall protection.
 - b. Target: 100% of all company devices.

8.1.2 Review Schedule of the Cybersecurity Program

1. **Quarterly Reviews**: The IT support team will review progress on KPIs and assess risks on a quarterly basis to identify trends or vulnerabilities.
2. **Annual Security Audits**: Conducted to ensure compliance with industry standards and assess the effectiveness of current security measures.
3. **Triggered Reviews**: Reviews will take place during significant business changes, such as implementing new payment options, launching new product partnerships, or integrating new technologies.

8.1.3 Continuous Improvement Methodology

Green Foods Market will adopt a proactive approach to continuously evaluate and strengthen its cybersecurity by focusing on feedback, analysis, and adaptation:

- **Identify & Analyze:** Regularly review security audit results, KPI trends, and employee feedback to pinpoint potential risks or areas for improvement.
- **Implement Changes:** Introduce updates, security patches, or enhanced policies to address identified vulnerabilities and evolving threats.
- **Evaluate Impact:** Monitor the performance of implemented changes by tracking KPIs and reviewing incident response data.
- **Adapt & Optimize:** Refine strategies and security measures based on insights, audit findings, and new technological advancements.

8.1.4 Reporting

- **IT Support/Website Support Team:** Provide monthly updates to leadership regarding cybersecurity incidents, threat assessments, and KPIs.
- **Leadership Team:** Review progress quarterly and plan for strategic improvements.
- **Manager:** Send quarterly updates to all employees via email to maintain transparency, share successes, and recognize employee efforts toward cybersecurity.

8.2 Conclusion

The cybersecurity strategy for Green Foods Market is designed to protect customer data, maintain operational security, and strengthen consumer trust. Key objectives include:

- **Protecting Customer Data:** Encrypting payment and personal information during transactions to minimize the risk of breaches.
- **Improving Risk Detection:** Biannual audits to identify vulnerabilities and implement proactive solutions.
- **Employee Security Awareness:** Training employees to strengthen the human element of security, reducing the risk of user-related threats.
- **Faster Incident Response:** Enhancing the ability to respond to security incidents quickly to minimize risk to operations and customer trust.
- **Patch Management and Compliance:** Regular system updates and timely patch implementation to protect against threats and maintain compliance with industry standards.

9.0 Revision History Table

The table below includes the revision history for this document.

Version	Author	Date	Changes
v 0.1.0	Samual O'Bryant	02/23/24	Initial outline/rough draft
v 0.2.0	Eru Chitanda	02/30/24	Final draft
v 0.3.0	Samual O'Bryant	03/14/24	Revised patch management policy
v 1.0.0	Samual O'Bryant	04/17/24	Added social media standard and final approval by owner and IT team
v 1.2.0	Julian Iglesias	06/21/24	Included updated asset list
v 2.0.0	Julian Iglesias	07/02/24	Approved by Owner/Manager

Table 7 - Revision History Table

9.1 Change Control Process

Any changes made to this cybersecurity plan must be vetted through the following change control process. The steps for making updates and revisions are as follows:

1. A change request form must be completed and presented to the owner for approval.
2. The form must be reviewed by the owner and at least one IT team member. If changes must be made, the form shall be filled out and presented again.
3. Once approved, the proposed changes will be made to the cybersecurity plan document by the owner and IT team.
4. The necessary changes are scheduled, and all employees are notified of the revisions.
5. Any third-party contractors or customers are notified if required.
6. The revision table above is updated with the version number, author, date, and changes made after the previous draft is preserved.

Appendices

Appendix A – Sample Policy

ENCRYPTION POLICY FOR GREEN FOODS MARKET

Responsible Executive: John Smith
Responsible Office: Management and IT
Date Issued: December 14, 2024
Date Last Revised: December 13, 2024
Version: 2.0

CONTACTS

Title/Office	Telephone	Email/Webpage
Store Owner	856-999-9977	Jsmith@greenfoodsmarket.com

Table 8-Contact

INTRODUCTION

At Green Foods Market, protecting customer sensitive information is essential to maintain customer trust. This policy establishes guidelines and practices for using encryption to ensure sensitive information is secure.

STATEMENT OF POLICY

Green Foods Market secures sensitive data by implementing the use of encryption technologies. All employees, contractors, and third-party vendors accessing or managing Green Foods Market’s digital systems are required to comply with the encryption practices outlined in this policy. This includes the encryption of all sensitive data in storage, transmission, and processing.

PURPOSE

The purpose of this policy is to provide clear guidelines for the use of encryption to protect sensitive customer payment information at Green Foods Market. This policy is designed to safeguard sensitive information from unauthorized access while maintaining confidentiality, integrity, and availability always.

SCOPE

This policy applies to all employees, contractors, third-party vendors, and any individual with access to Green Foods Market’s data. It covers all forms of sensitive data, whether stored on company systems, transmitted across networks, or stored on removable media.

ENCRYPTION POLICY GUIDELINES

1. Data to be Encrypted

All data listed below must be encrypted:

- i. Customer payment card information.
- ii. Customer Personal Identifiable Information (PII).

2. Encryption Standards Required

- i. All data at rest must be encrypted using AES-256.
- ii. Data in transit must be encrypted using TLS 1.2

3. Stored Data Encryption

- i. All sensitive data stored on the company system must be encrypted.
- ii. Similarly, cloud storage used for sensitive data must support and enforce encryption both at rest and in transit.

4. Encryption Key Management

- i. Encryption keys must be securely managed and stored.
- ii. Only authorized personnel should have access to encryption keys.

ROLES and RESPONSIBILITIES

Owner/Manager: Oversees the implementation and adherence of this policy

IT Support Team: Ensures sensitive data is encrypted using encryption tools.

Employees: Adhere to this policy when handling sensitive customer data.

EXCLUSIONS

This policy does not currently have any exclusions. However, any exceptions to this policy must be approved in writing by the owner/manager.

ENFORCEMENT

Failure to comply with this policy may result in disciplinary action such as a written or verbal warning, suspension, legal action or at most termination of employment. Purposeful circumnavigation of PII encryption will result in termination.

DEFINITIONS

- **Sensitive Data:** Includes customer PII and payment card data.
- **Encryption:** The process of converting data into a coded format to prevent unauthorized access.
- **Key Management:** The administration of cryptographic keys used in the encryption process.

Appendix B – Sample Standard

Responsible Executive: John Smith

Responsible Office: Management and IT

Date Issued: January 1, 2025

Date Last Revised: December 13, 2024

1. Objective

This standard ensures the protection of sensitive customer and business data and upholds cybersecurity best practices at Green Foods Market.

2. Scope

Applies to all employees, third-party vendors, and contractors with access to Green Foods Market's information systems and data.

3. Data Protection

- **Encryption:** Sensitive data (customer and employee info) must be encrypted using industry-standard encryption (e.g., SHA256, SHA512).
- **Data Storage:** Store sensitive data securely with access limited to authorized personnel only.
- **Data Transmission:** Data must be encrypted during transmission to prevent unauthorized access.

4. Access Control

- **Password Policies:** Require strong passwords (at least 12 characters, including letters, numbers, and special characters). Change every 90 days.
- **Two-Factor Authentication (2FA):** Implement 2FA for access to critical systems (not required for POS systems).
- **User Access:** Access to systems should be limited to the minimum necessary for each employee's role (principle of least privilege).

5. Incident Response

- **Incident Reporting:** Report any cybersecurity incidents or suspected breaches immediately to IT support.
- **Incident Response Plan:** Have a plan in place to contain, assess, and resolve security breaches, restoring normal operations quickly.

6. Training and Awareness

- **Initial Training:** All new employees must complete cybersecurity training upon hiring.
- **Annual Refresher Courses:** Employees must take annual training to stay current on cybersecurity threats and best practices.

- **Awareness Programs:** Regular programs to keep staff informed about cybersecurity risks.

7. Software Updates

- **Regular Updates:** Apply the latest security patches and software updates regularly.
- **Update Schedule:** Maintain a schedule for consistent software updates and patches.

8. Compliance and Monitoring

- **Security Audits:** Conduct regular audits to ensure compliance with cybersecurity standards.
- **Monitoring:** Continuously monitor systems for potential security threats.
- **Disciplinary Actions:** Violations of this standard may result in disciplinary action, including retraining or termination.

Definitions

- **Encryption:** Converting data into a code to prevent unauthorized access.
- **Two-Factor Authentication (2FA):** A security measure that requires two forms of identification to access a system.
- **Principle of Least Privilege:** Granting users only the access necessary for their role.

This **Business Standard** provides a clear framework for maintaining cybersecurity at Green Foods Market, ensuring the protection of sensitive data and the security of systems and operations.

Appendix C – Sample SOP

Standard Operating Procedure (SOP)

Modifying an Item in the Store Database via Menu System

Green Foods Market

1. Purpose

This SOP provides a standardized process for modifying inventory items or quantities in the store's database using the menu system.

2. Scope

This SOP applies to all employees authorized to access and modify the inventory system through the menu system. It covers both updates to existing items and removing items from the inventory database.

3. Responsibilities

- **Store Clerks/Inventory Staff:** Responsible for following this SOP to update or remove inventory items when required.
- **IT Support Team (3rd party):** Provide assistance with troubleshooting the system or menu options if needed.

4. Procedures

4.1 Logging into the System

1. Log into the Terminal:

- a. Access the terminal by pressing the "Enter" key.
- b. Enter your **username** and **password** when prompted.
- c. Press **Enter** to log in.

4.2 Navigating to the Inventory Menu

1. Access the Inventory Menu:

- a. After logging in, you will be presented with the main menu.
- b. Use the **arrow keys** to scroll down to the option labeled "**Inventory Management**".
- c. Once the option is highlighted, press **Enter** to select it.

4.3 Searching for the Item

1. Search for an Item:

- a. In the "Inventory Management" menu, use the **arrow keys** to select "**Search Inventory**" and press **Enter**.
- b. You will be prompted to enter search criteria (e.g., **Item Name**, **SKU**, or **Product Code**).
- c. After entering the search criteria, press **Enter** to display a list of matching items.

2. Locate the Item to Modify:

- a. Use the **arrow keys** to scroll through the list and highlight the item you wish to modify.
- b. Once the item is highlighted, press **Enter** to select it.

4.4 Modifying the Item

1. Initiate Edit Mode:

- a. Once the item is selected, press **I** to initiate editing the item details (you will be able to modify the item's quantity, price, or remove it entirely).

2. Change Quantity (or Other Details):

- a. Use the **arrow keys** to navigate to the field you want to modify (e.g., **Quantity**).
- b. Enter the new value for the field (e.g., adjust the quantity or update the price).
- c. Press **Enter** to confirm the edit.

3. Remove an Item:

- a. To remove an item from the inventory, navigate to the **Delete** option (usually available under "Options" or "More Actions").
- b. Use the **arrow keys** to select "**Delete Item**", then press **Enter**.
- c. Confirm the deletion by pressing **Enter** again when prompted.

4.5 Finalizing and Saving Changes

1. Save Changes:

- a. After making changes (e.g., updating quantity or removing an item), press **Enter** to finalize the modification.
- b. The system will prompt you with a confirmation message (e.g., "Changes saved successfully").
- c. Press **Enter** to confirm and return to the menu.

2. Exit Item Edit Mode:

- a. Once the item has been modified, use the **arrow keys** to select "**Exit**" or press **Esc** to return to the main inventory menu.

4.6 Logging Out of the System

1. Log Out:

- a. Once all changes are complete, use the **arrow keys** to select the "**Sign Off**" or "**Exit**" option from the main menu.
- b. Press **Enter** to log out of the system.

5. Training & Awareness

- All store clerks and inventory staff must receive training on how to navigate and modify items in the inventory system using the menu system.

- Staff must complete a training session after hiring and participate in annual refresher courses to ensure familiarity with any updates to the process.

6. Incident Response

- **In Case of System Error:**
 - If the system fails to save changes or encounters an error, immediately notify the IT support team for troubleshooting.
 - Do not attempt to make further changes until the issue is resolved to prevent data discrepancies.

Revision History:

Version	Date	Author	Descript	Approved By
1.0	12/13/14	John Smith	Initial SOP Draft	Ricky Martin

Table 9-SOP Revision Table

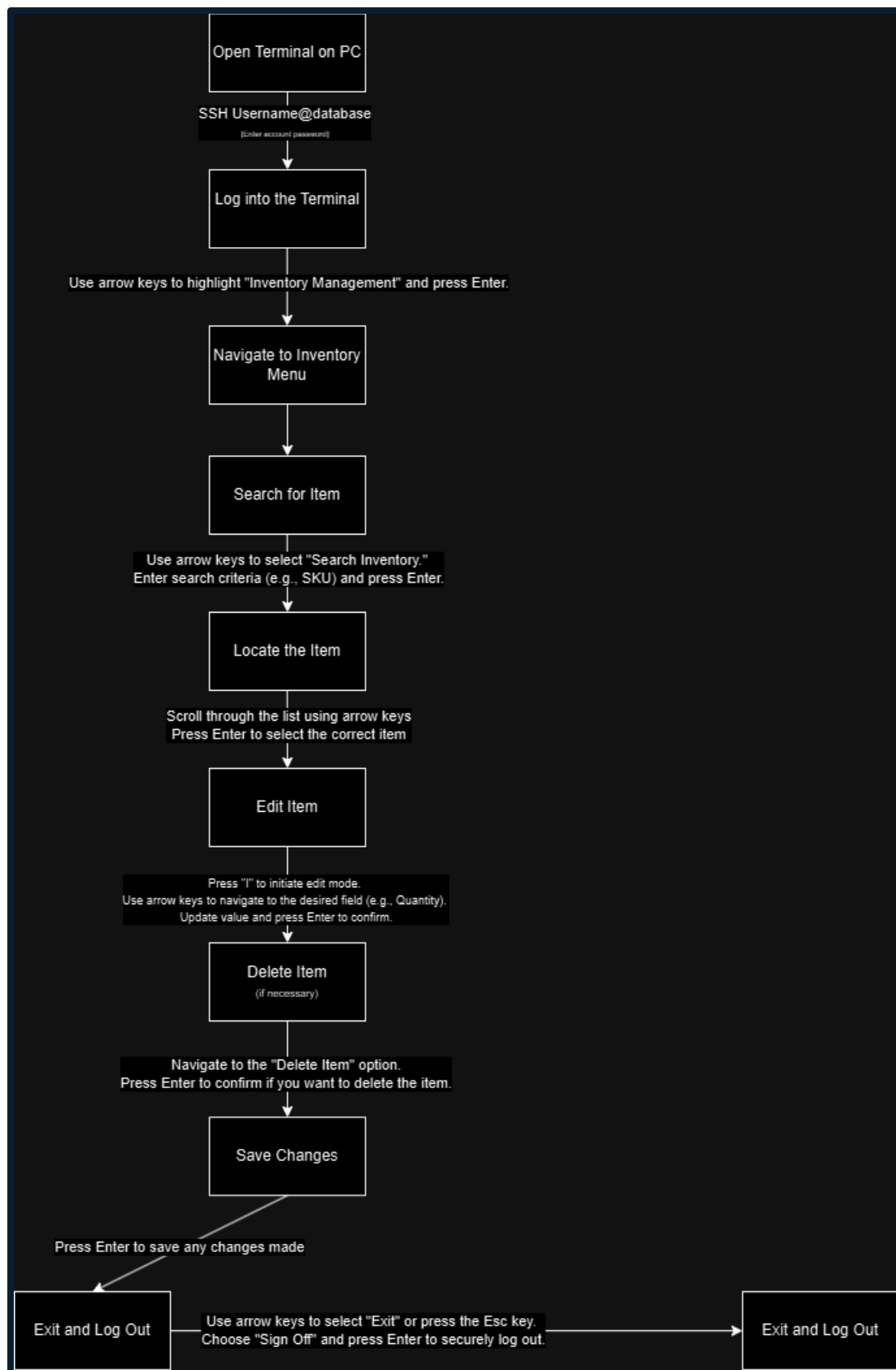


Figure 1- Modifying an Item in the Store Database via Menu System